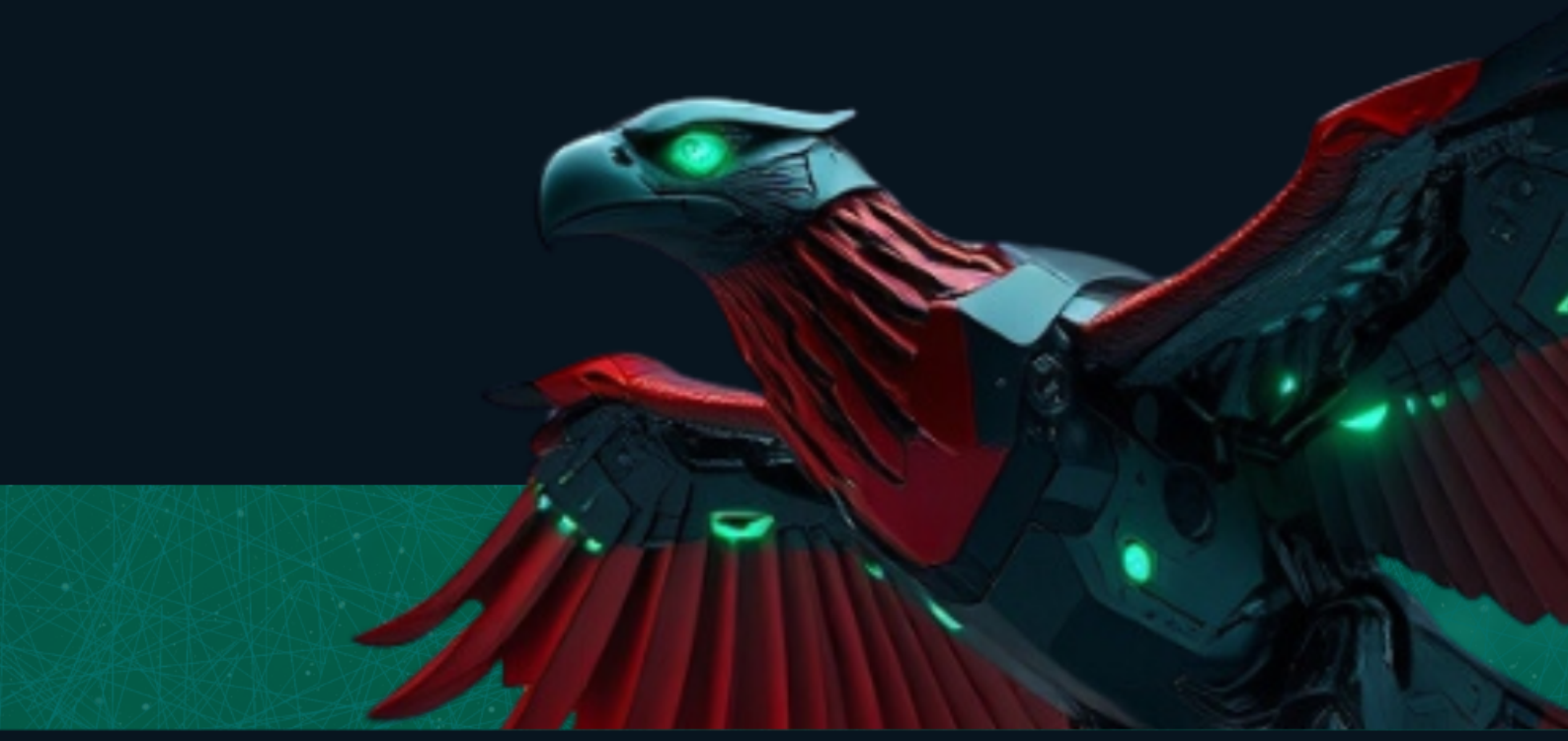
SOCBYTE
ALL BYTES SECURED

INTEL REPORT



Report Details

Title	Threat Hunt | Punk Spider
Sub Title	Active, financially motivated cybercriminal threat group categorized as a "Big Game Hunting" adversary
Status	Closed
Type	Alert
Severity	—
Source	Multiple Sources
Created At	Jul 01, 2026, 02:46 PM

Threat Hunt | Punk Spider

Active, financially motivated cybercriminal threat group categorized as a "Big Game Hunting" adversary

Type: ALERT • Source: Multiple Sources • Created At: Jul 01, 2026, 02:46 PM

Analysis Summary

On July 1st at 2:04PM, Cythority's vSOC conducted a threat hunt focused on Punk Spider, covering activity within the past 30 days. Punk Spider is an active, financially motivated cybercriminal threat group categorized as a "Big Game Hunting" adversary. First spotted in April 2023, the group is primarily recognized by threat intelligence analysts as the core operator, developer, and maintainer behind the notorious Akira ransomware-as-a-service platform and its associated dedicated leak site.

Operating globally across a vast array of sectors - including technology, healthcare, critical infrastructure, and government - the group is known by several community and vendor-specific identifiers, including Storm-1567, GOLD SAHARA, REDBIKE, and Darter. The threat actor heavily relies on a highly impactful double-extortion model. Instead of simply encrypting a victim's environment, Punk Spider actors first exfiltrate massive amounts of sensitive enterprise data to external cloud storage providers. Once the data is secured, they deploy cross-platform variants of the Akira ransomware to encrypt critical business systems, hypervisors (such as VMware ESXi and Nutanix AHV), and local backups. To maximize their leverage during negotiation, they systematically delete Windows Volume Shadow Copies to prevent native data recovery and threaten to publish the stolen data on the dark web if their multi-million dollar ransom demands are not met.

Tactically, Punk Spider acts as a sophisticated, agile adversary that prefers to "live off the land" rather than rely entirely on custom-built malware. They frequently secure initial access by targeting unmanaged or unpatched edge devices, aggressively exploiting known vulnerabilities in public-facing VPN appliances (such as Cisco, Fortinet, and SonicWall devices), or abusing valid, single-factor credentials. Once inside a network, they blend in with legitimate traffic by utilizing built-in administrative scripts alongside common

post-exploitation tools like Mimikatz, Advanced IP Scanner, Rclone, and AnyDesk to disable endpoint security controls, harvest credentials, map out active directories, and rapidly pivot laterally across the network.

During this hunt, a total of 17 Indicators of Compromise (IOCs) were identified, including domains, IP addresses, and file hash values. These indicators were aggregated from CrowdStrike, internal telemetry, and additional intelligence sources referenced in this report. All identified IOCs were enriched using OSINT and threat intelligence platforms to validate their reputation. Analysis confirmed that the indicators are associated with malicious activity.

A CQL Advanced Event Search was conducted across the environment to identify any evidence of activity related to these indicators. No matches or suspicious activity were observed, confirming no current or historical presence within the environment. As a preventative measure, the validated malicious IOCs have been added to the IOC Management Block List to mitigate potential future exposure. This proactive control strengthens the security posture and reduces the attack surface.

Based on the investigation and analysis performed, no impact to the environment has been identified and no further action is required at this time.

Targeted Industries:

Government, Technology, Retail, Legal, Automotive, Maritime, Entertainment, Utilities, Consumer Goods, Local Government, Aviation, Academic, Telecommunications, Consulting and Professional Services, Industrials and Engineering, Architectural and Engineering, Real Estate, Transportation, NGO Manufacturing, Logistics, Hospitality, Travel, Financial Services, Agriculture, Media, Healthcare, Energy, Sports Organizations, Aerospace, Nonprofit, Food and Beverage, Chemicals

Targeted Countries:

China, Canada, Czech Republic, Hong Kong, Sweden, Switzerland, Italy, South Africa, Curacao, Ireland, Bangladesh, Norway, Panama, Belgium, Chile, Andorra, Guyana, Indonesia, Finland, Denmark, Nicaragua, Poland, Spain, Slovenia, Taiwan, Greece, Netherlands, Georgia, United States, Mexico, Germany, Australia, Argentina, Thailand, Saudi Arabia, France, Ecuador, Austria, Lithuania, New Zealand, Japan, United Kingdom, Brazil, Singapore, Portugal, India, Romania, Puerto Rico

Community Identifiers:

Akira, Storm-1567, REDBIKE, Darter

Affected Product

- Edge & Remote Access Products
- Virtualization & Infrastructure Hypervisors
- Enterprise Backup & Data Management Software
- Operating Systems

Impact

- Massive Data Exfiltration and Exposure
- Widespread Operational Disruption
- Destruction of Native Recovery Options
- Severe Financial Loss
- Compromised Perimeter Security and Credential Theft
- Long-Term Reputational Damage

Indicators of Compromise (IOCs)

MD5 Hashes

- Ab94023e14dd50565704857b12952e54
- D3cf7a81ddd61e65fc4773257331325d
- 1b37c5509eb7d5f7641d1e5846aa224c
- A48060248c624cb8edce7415dcf142b1
- 74f27fb712ad76c9b39398c93e5d94a8

SHA256 Hashes

- Bd3a93a17a89ea67e9bd08df7aa5feeeca18dd7c1e01687d293d649539416e18
- E7a44ea5adc366e7600623e7ff433d57cf3ba0bfac8171899497fec6c8a28acc
- B8ed237d1cfef4f1cefaeb06219be94b8fbb8cf404369b4f3734deeccb3e1079
- 0fe572e7aad25a38ba9ee9b4600ddc02641e29061de250c525d6828f70326005
- Fd84c9c09358e721173725d0a1eeae08cd0c6d74b2f44646552adc4b19883e90

IP

- 148.72.168[.]13
- 108.62.60[.]37
- 170.130.55[.]117
- 158.255.213[.]74
- 107.155.93[.]154

DOMAIN

- akiral2iz6a7qgd3ayp3l6yub7xx2uep76idk3u2kollpj5z3z636bad[.]onion
- Akiralkzxzq2dsrzsrvbr2xgbbu2wgsmxryd4csgfameg52n7efvr2id[.]onion

Remediation

- Patch Public-Facing Edge Devices Immediately
- Enforce Phishing-Resistant MFA
- Filter TOR and Tunneling Infrastructure
- Host-Based LSASS Protection
- Restrict Command-Line and Scripting Execution
- Network Segmentation & Just-In-Time (JIT) Access

- Harden Hypervisor Access Control
- Deactivate Unused Administrative Protocols
- Maintain Immutable and Offline Backups
- Regularly Test Disaster Recovery Plans